

5.1.3 Practice - Windows Name Resolution and SMB Attacks

You have gained access to a host on a Windows domain at Pixel Paradise. A scan reveals that UDP port 5355 is open on a device that is running a version of the Windows server software. You suspect that LLMNR is in use on the network. This may enable you to exploit the domain server. You decide to run a LLMNR spoofing attack to see what information you can gather. What can you find out using this approach? Choose two.

enterprise workgroup names

the names of hidden shares



usernames



NTLMv2 hashed passwords

the value of registry key HKLM\Software\Policies\Microsoft\Windows NT\DNSClient

Skills Check

You are working to exploit existing SMB vulnerabilities in the Pixel Perfect network, if any exist. What is the first step you will take when conducting an SMB attack in the network?



Conduct a scan to discover if TCP ports 139 and 445 are open on any hosts in the network.

Run enum4linux against the network to determine the SMB version.

Use enum4linux to reveal password policies to guide brute force attacks against hosts.

Use smbclient to broadcast SMB queries on the LAN in order to analyze the replies in enum4linux.

5.1.6 Practice - DNS Cache Poisoning

You have successfully conducted a small-scale DNS poisoning attack that affected a few hosts on a Pixel Paradise LAN. When it is time to write up the final penetration test report, what will you recommend as three important mitigation measures that Pixel Paradise should take to mitigate such attacks? (Choose three.)

- Restrict access to all the default root servers built into the Windows DNS database.
- ☒ Use the features of BIND 9.5.0 or higher for randomization of ports and provision of cryptographically secure DNS transaction identifiers.
- Allow multiple trust relationships between DNS servers.
- Allow multiple recursive DNS queries.
- ☒ Only store data related to the requested domain, and restrict query responses to provide information about the requested domain.
- ☒ Implement DNSSEC technologies.

5.1.9 Practice - SMTP Commands

After performing a scan of the Pixel Paradise network, you discover that a mail server is running both SMTP and Telnet on port 25. You have identified the plaintext Telnet password in a packet capture file that you recorded. You decide establish a Telnet session to port 25 on the server and try to determine the member addresses in some commonly used mailing list aliases. Which SMTP command will allow you to accomplish this exploit?

- RSET
- VRFY
- ☒ EXPN
- RCPT

5.1.15 Practice - Kerberos, LDAP, and On-Path Attacks

Your pen testing team has completed the reconnaissance phase of the test and are planning the exploitation phase. The team has been successful with a variety of different attacks in the past. In order to participate in the next phase of the engagement, it is important that you are familiar with the types of attacks that are under discussion. Match the attack type with its description.

Categories:

Pass-the-Hash

Kerberoasting

Kerberos golden ticket

Kerberos silver ticket

On-Path

Options:

In this attack, an attacker exploits a combination of weak encryption implementations and improper password practices to extract service account credential hashes from Active Directory for offline cracking.

In this type of attack, an attacker can use a password hash collected from a compromised system to log into another client or server.

In this type of attack, an attacker can manipulate Kerberos tickets based on available hashes by compromising a vulnerable system and obtaining the local user credentials and password hashes.

In this type of attack, the attacker intercepts communications between two or more communicating devices in order to steal or modify sensitive data.

In this type of attack, the attacker uses a forged service authentication ticket for a given service on a particular server to compromise accounts on the server.

A

B

B

A

C

C

D

E

E

D

Skills Check

You are attempting to exploit a LAN by conducting an ARP-spoofing on-path attack. Which MAC address value will you map to the default gateway IP address in the ARP caches of the target computers?

that MAC of the target computer

the broadcast MAC

✓

the MAC of the attacker

the MAC of the target server

5.1.19 Practice - DoS and DDoS Attacks

You have been asked to test the resilience of the Pixel Paradise commerce website by carrying on a direct DDoS attack. What will you do to execute this test?



Use a testing botnet to generate half-open TCP connections on the server.

Use a hacker tools VM to flood the host with crafted packets.

Send DNS queries with the victim's spoofed source address that result in large responses from a DNS open-resolver.

Send ping requests with the victim's spoofed source address to a group of testing hosts.

5.1.22 Practice - NAC Bypass and VLAN Hopping

Question 1

Protego routinely tests Network Access Control (NAC) implementations. You have identified a VoIP VLAN that has been configured on the Pixel Paradise the network. How can you test NAC on this VLAN for access control vulnerabilities?

by using SpoofCard



by using MAC address spoofing

by using Asterisk

by using SpoofApp

Submit



Show feedback

Question 2

During testing of a customer network, you were able to access a LAN segment and capture traffic with Wireshark. Analysis shows that user traffic is tagged with the default native VLAN ID for the type of switch that is in use. This configuration makes the LAN vulnerable to VLAN double tagging attacks. What recommendation should you make to the customer regarding how to mitigate this vulnerability?



Change the native VLAN from VLAN 1 and remove all access ports from it.

Bring up the ports on the respective switch and assign VLANs as the ports are allocated and needed.

Use a native VLAN only for the enabled access ports.

Do not use a dedicated VLAN ID for all trunk ports.

5.1.24 Practice - DHCP Starvation and Rogue DHCP Servers

In the Pixel Paradise pen testing engagement, a single LAN has been designated as in-scope for disruptive tests. You are able to access the LAN over VPN and connect a DHCP server that is running in your ethical hacking tools VM. Which exploits will this server enable you to perform? Choose two.

- Phishing
- ☒ MITM
- Disassociation
- ARP spoofing
- ☒ DoS

5.2.11 Practice - IV, Unsecured Wireless, KARMA, and Fragmentation Attacks

Question 1

True or False:
The WPA3 protocol introduced a new handshake called the “dragonfly handshake” that uses Extensible Authentication Protocol (EAP) for authentication. This ensures that the WPA3 protocol is immune from KRACK or DoS attacks.

- True
- ☒ False

Question 2

Pixel Paradise has configured their WLAN to not broadcast its SSIDs. You have set up Airodump-ng to sniff wireless traffic in order to capture SSIDs as a starting point for your wireless pentest. Because the SSIDs are not broadcast, what needs to happen in order for an SSID to be intercepted by the wireless sniffer?

- Clients must be redirected to your rogue AP through DNS spoofing.
- You should configure a spoofed MAC address on your testing computer wireless interface.
- ☒ A legitimate client needs to initiate the association process with an AP.
- You must crack the WPA PSK.

5.2.18 Practice - Wireless Attacks

Match the type of wireless attack with its description.

Categories:

Bluejacking

War Driving

Evil Twin Attacks

Disassociation

Wireless signal jamming

Password Spraying

KARMA

Options:

In this type of attack, the attacker tries to disconnect the user from the authenticating wireless AP and then carries out another attack to obtain the valid credentials of the user.

✓

In this type of attack, the attacker roams to find wireless access points wherever they might be located.

✓

In this type of attack, the attacker uses DNS spoofing to redirect the victim to a cloned captive portal or a website. When users are logged on to the clone, a hacker can easily inject a spoofed DNS record into the DNS cache, changing the DNS record for all users on the fake network.

✓

In this type of attack, the attacker tries to create a full or partial DoS condition in the wireless network by generating random noise on the frequencies that wireless networks use.

✓

In this type of attack, an attacker could institute an on-path attack by modifying the Bluetooth Low Energy (BLE) messages between systems leading them to think they are communicating with legitimate systems.

✓

In this type of attack, the attacker listens for the probe requests from wireless devices and intercepts them to generate the same SSID for which the device is sending probes.

✓

In this type of attack, an attacker brute-forces logins (that is, attempts to authenticate numerous times) based on a list of usernames with default passwords of common systems or applications.

✓

```
graph LR; A((A)) --- E1[In this type of attack, the attacker tries to disconnect the user from the authenticating wireless AP and then carries out another attack to obtain the valid credentials of the user.]; B((B)) --- B1[In this type of attack, the attacker roams to find wireless access points wherever they might be located.]; C((C)) --- C1[In this type of attack, the attacker uses DNS spoofing to redirect the victim to a cloned captive portal or a website. When users are logged on to the clone, a hacker can easily inject a spoofed DNS record into the DNS cache, changing the DNS record for all users on the fake network.]; D((D)) --- D1[In this type of attack, the attacker tries to create a full or partial DoS condition in the wireless network by generating random noise on the frequencies that wireless networks use.]; E((E)) --- A1[In this type of attack, an attacker could institute an on-path attack by modifying the Bluetooth Low Energy (BLE) messages between systems leading them to think they are communicating with legitimate systems.]; F((F)) --- F1[In this type of attack, the attacker listens for the probe requests from wireless devices and intercepts them to generate the same SSID for which the device is sending probes.]; G((G)) --- G1[In this type of attack, an attacker brute-forces logins (that is, attempts to authenticate numerous times) based on a list of usernames with default passwords of common systems or applications.];
```

Question 1

Which NetBIOS service is used for connection-oriented communication?

- NetBIOS-NS
- NetBIOS-DGM
-  NetBIOS-SSN
- LLMNR

Question 2

Match the port type and number with the respective NetBIOS protocol service.

Categories:

UDP port 138

UDP port 137

TCP port 445

TCP port 139

TCP port 135

Options:

 NetBIOS Datagram Service

 NetBIOS Name Service

 SMB protocol

 NetBIOS Session Service

 Microsoft Remote Procedure Call (MS-RPC)

A

B

C

D

E

A

B

C

D

E

Question 3

What two features are present on DNS servers using BIND 9.5.0 and higher that help mitigate DNS cache poisoning attacks? (Choose two.)

-  randomization of ports
-  provision of cryptographically secure DNS transaction identifiers
- exclusion of any trust relationships between DNS servers
- secure DNS data authentication
- prevention of any recursive DNS queries

Question 4

What UDP port number is used by SNMP protocol?

- ☒ 161
- ☐ 182
- ☐ 128
- ☐ 176

Question 5

Which is a characteristic of a DNS poisoning attack?

- ☐ The DNS server forward lookup zone is cleared.
- ☐ The DNS server reverse lookup zone is cleared.
- ☒ The DNS resolver cache is manipulated.
- ☐ The DNS server IP address is changed.

Question 6

Which Kali Linux tool or script can gather information on devices configured for SNMP?

- ☒ snmp-check
- ☐ nslookup
- ☐ snmp-brute.nse
- ☐ snmp-netstat.nse

Question 7

Match the SMTP command with the respective description.

Categories:

MAIL

A

RSET

B

EHELO

C

DATA

D

STARTTLS

E

HELO

F

Options:

✓

used to denote the email address of the sender

✓

used to cancel an email transaction

✓

used to initiate a conversation with an Extended Simple Mail Transport Protocol server

✓

used to initiate the transfer of the contents of an email message

✓

used to start a Transport Layer Security connection to an email server

✓

used to initiate an SMTP conversation with an email server

Question 8

Which two best practices would help mitigate FTP server abuse and attacks? (Choose two.)

limit anonymous logins to a select group of people

edit the hosts file to limit the number of authorized DNS servers

✓

use encryption at rest

consolidate all back-end databases on the FTP server

✓

require re-authentication of inactive sessions

Question 9

Which is a characteristic of the pass-the-hash attack?



capture of a password hash (as opposed to the password characters) and using the same hashed value for authentication and lateral access to other networked systems

reverse engineering of the captured hash password and using the unencrypted password for authentication and lateral access to other networked systems

compromise of a SAM file and extraction of the password characters to use for authentication and lateral access to other networked systems

capture of the Windows password before the Kerberos hashing function and use of the unencrypted password for authentication and lateral access to other networked systems

Question 10

What is a Kerberoasting attack?

It is an attempt to steal the hash value of a user credential and use it to create a new user session on the same network.

It attempts to manipulate Kerberos tickets based on available hashes by compromising a vulnerable system and obtaining the local user credentials and password hashes.



It is a post-exploitation attempt that is used to extract service account credential hashes from Active Directory for offline cracking.

It attempts to manipulate data being transferred by performing data corruption or modification.

Question 11

Match the attack type with the respective description.

Categories:

Reflected DOS

A

A

✓

DNS Amplification

B

B

✓

Direct DOS

C

C

✓

DDOS

D

D

✓

Options:

This attack uses spoofed packets that appear to be from the victim. Then the sources become unwitting participants in the attack by sending the response traffic back to the intended victim.

This an attack in which the attacker exploits vulnerabilities in target servers to initially turn small queries into much larger payloads, which are used to bring down the servers of the victim.

This occurs when the source of the attack generates the packets, regardless of protocol, application, and so on, that are sent directly to the victim of the attack.

This attack uses botnets that can be manipulated from a command and control (CnC, or C2) system.

Question 12

Match the attack type with the respective description.

Categories:

Route Manipulation attacks

A

A

✓

Downgrade attacks

B

B

✓

DHCP Starvation attack

C

C

✓

VLAN Hopping attack

D

D

✓

MAC address spoofing attack

E

E

✓

Options:

typically a BGP hijacking attack by configuring or compromising an edge router to announce prefixes that have not been assigned to the organization

the attacker forces a system to favor a weak encryption protocol or hashing algorithm that may be susceptible to other vulnerabilities

an attacker floods a server with bogus DISCOVER packets until the server exhausts the supply of IP addresses

an attacker bypass any layer 2 restrictions built to divide hosts

an attacker spoofs the physical address of the NIC device to match the address of another on a network in order to gain unauthorized access or launch a Man-in-the-Middle attack

Question 13

Which tool can be used to perform a Disassociation attack?

- ☒ Airmon-ng
- ☐ nmap
- ☐ POODLE
- ☐ EMPIRE

Question 14

Which is a characteristic of a Bluesnarfing attack?

- ☐ An attack that is launched using common social engineering attacks, such as phishing attacks, can be performed by impersonating a wireless AP or a captive portal to convince a user to enter the user credentials.
- ☐ An attack that can be performed using Bluetooth with vulnerable devices in range. It is commonly performed as spam over Bluetooth connections using the OBEX protocol.
- ☒ An attack that can be performed using Bluetooth with vulnerable devices in range. This attack actually steals information from the device of the victim.
- ☐ An attack involves modifying BLE messages between systems that would lead them to believe that they are communicating with legitimate systems.

Question 15

Which Wi-Fi protocol is most vulnerable to a brute-force attack during a Wi-Fi network deployment?

- ☐ WPA2-EAP
- ☒ WPS
- ☐ WPA3
- ☐ WPA2-TKIP

Question 16

What does the MFP feature in the 802.11w standard do to protect against wireless attacks?

- It uses a PNL to maintain a list of trusted or preferred wireless networks.
- It uses a captive portal for all wireless associations.
- It inserts the 802.1q tag to protect the wireless frame.
- ☒ It helps defend against deauthentication attacks.

Question 17

What is a DNS resolver cache on a Windows system?

- It is a database of all WINS records.
- It is a static database entry of all forward and reverse lookup zones.
- ☒ It is a temporary database that contains records of all the recent visits and attempted visits to websites and other internet domains.
- It is a collective database of all Domain Name Service records of static and cached entries.

Question 18

Match the TCP port number with the respective email protocol that uses it.

Categories:

465

587

143

995

993

Options:

A

☒

The port registered by the Internet Assigned Numbers Authority (IANA) for SMTP over SSL (SMTPS).

B

☒

The Secure SMTP (SSMTP) protocol for encrypted communications, as defined in RFC 2487, using STARTTLS.

C

☒

The default port used by the IMAP protocol in non-encrypted communications.

D

☒

The default port used by the POP3 protocol in encrypted communications.

E

☒

The default port used by the IMAP protocol in encrypted (SSL/TLS) communications.

A

B

C

D

E

Question 19

Which is the default TCP port used in SMTP for non-encrypted communications?

- ☒ 25
- ☐ 110
- ☐ 143
- ☐ 993

Question 20

What is a characteristic of a Kerberos silver ticket attack?

- ☒ It uses forged service tickets for a given service on a particular server.
- ☐ It mimics the authentication hash on a particular server.
- ☐ It acts as the LDAP directory for authentication on a target server.
- ☐ It covertly hashes the value to the unencrypted value for an authentication attack on a particular server.

Question 21

Which attack is a post-exploitation activity that an attacker uses to extract service account credential hashes from Active Directory for offline cracking?

- ☐ MITM
- ☐ On-Path attack
- ☐ MAC spoofing
- ☒ Kerberoasting

Question 22

Which four items are needed by an attacker to create a silver ticket for a Kerberos silver ticket attack? (Choose four.)

- hash value
- ☒ system account
- ☒ SID
- ☒ FQDN
- ☒ target service
- DNS forward lookup zone
- DNS resolver cache
- DNS reverse lookup zone

Question 23

Which kind of attack is an IP spoofing attack?

- ☒ On-path
- DDoS
- Pass-the-Hash
- Evil-Twin

Question 24

What is a common mitigation practice for ARP cache poisoning attacks on switches to prevent spoofing of Layer 2 addresses?

- DHCP snooping
- DNSSEC
- ☒ DAI
- BIND 9.5

Question 25

An attacker is launching a reflected DDoS attack in which the response traffic is made up of packets that are much larger than those that the attacker initially sent. Which type of attack is this?

- downgrade
- ☒ amplification
- on-path
- DNS cache poisoning